The password-based authentication system developed in Lab 1 was a very basic application, so it had several security weaknesses. First, it did not have multi-factor authentication, such as sending a verification code to a phone number, email, or authentication app. Second, users' passwords were stored in plaintext, which made them readable and easier for attackers to steal. Also, the password requirements were very simple, making it easier for attackers to guess passwords.

Another weakness was that the application did not have account locking, so an attacker could try guessing passwords many times without any limitation. Also, the password reset process was very simple. In my code, the security question was a general question, such as "What city were you born in?" An attacker could easily guess or find this information and use it to reset another user's password. The application also did not have login notifications or proper session management to help protect user accounts.

What design principles are applied in this security requirement?

1. Fail-Safe Defaults: If a user enters an incorrect username or password, the system denies access. After three failed login attempts, the account is temporarily locked for 60 seconds.

2. Complete Mediation: Every time a user tries to log in, the system checks their username and password to make sure they are correct. It also checks if the account is locked before allowing login.

3. Least Privilege: Users should only get access after successfully logging in. Someone who is not authenticated should not be allowed to access protected parts of the application.